MANUAL DE INSTRUCCIONES PRÁCTICAS EN KALI LINUX

Guía paso a paso de configuración de laboratorio, detección defensiva, análisis de tráfico y obtención de capturas reales para complementar la Práctica Integradora de Ciberseguridad (Opción A)

🔒 **Alcance Ético y de Seguridad (Clase 14 – Reglas de Trabajo RoE):** Todas las verificaciones de este manual están diseñadas para ejecutarse de forma **defensiva y local** dentro de tu propia máquina virtual Kali Linux (sobre `localhost` / `127.0.0.1` o en una red interna aislada de VirtualBox), enfocándose en la **detección, análisis de configuración, monitoreo con Wireshark y remediación**, sin realizar ataques contra terceros.

Fase 1: Preparación y Verificación de tu Entorno Kali Linux (Clase 3)

Paso 1.1 – Aislar la red del laboratorio en VirtualBox

1. En la ventana de **Oracle VM VirtualBox**, seleccioná tu máquina virtual de Kali Linux y entrá en **Configuración** → **Red**.
2. Si querés hacer pruebas 100% aisladas, configurá el Adaptador en **Red Interna (Internal Network)** o **Adaptador Sólo-Anfitrión (Host-Only)**. Si necesitás descargar algún paquete primero, podés usar *NAT* y luego pasar a red aislada.
3. Iniciá Kali Linux, abrí la **Terminal** y ejecutá los siguientes comandos para relevar la identidad de tu equipo y la configuración de red:

```
# 1. Ver fecha, nombre de host y versión del kernel de Kali Linux:
kali@kali:~$ uname -a && hostnamectl

# 2. Ver las interfaces de red y tu dirección IP privada (Clase 3 y Clase 10):
kali@kali:~$ ip a
# (o también podés usar: ifconfig)
```

> 📸 **Captura 1 para el Informe:** Tomá una captura de pantalla de la terminal mostrando la salida de `ip a` (o `ifconfig`) donde se vea tu IP privada. Podés sumarla en el Ejercicio 3 como evidencia de configuración de tu entorno Kali.

Fase 2: Auditoría de Puertos y Superficie de Ataque Local (Clases 8, 9 y 10)

Paso 2.1 – Inspeccionar puertos abiertos/cerrados y estado del Firewall en tu VM

En la **Clase 8** vimos los tres estados de un puerto (`Opened`, `Closed` y `Filtered`) y en la **Clase 9** la importancia de cerrar puertos innecesarios como el **TCP 445 (SMB)** para mitigar EternalBlue. Ejecutá en tu Kali:

```
# 1. Listar todos los puertos TCP/UDP que están escuchando localmente en tu Kali:
kali@kali:~$ sudo ss -tulnp

# 2. Verificar específicamente que los puertos SMB (139 y 445) NO estén expuestos:
kali@kali:~$ ss -tuln | grep -E ':(445|139)\b' || echo "SEGURO: Puertos 139 y 445 cerrados"

# 3. Verificar con Nmap sobre tu propia dirección de loopback (127.0.0.1) el estado de los puertos 80 y 445:
kali@kali:~$ sudo nmap -sV -p 80,139,445 127.0.0.1
```

> 📸 **Captura 2 para el Informe:** Capturá la salida de `sudo nmap -sV -p 80,139,445 127.0.0.1` mostrando cómo Nmap reporta los puertos `139/tcp` y `445/tcp` en estado `closed` (cerrados), demostrando cómo se verifica la mitigación de superficie de ataque.

Paso 2.2 – Inspeccionar el script defensivo de detección MS17-010 incluido en Kali

Kali Linux ya trae instalado de fábrica el catálogo de scripts NSE de Nmap. Podés mostrar en tu informe que verificaste la existencia y documentación del script detector de EternalBlue:

```
# Ubicar el script oficial de detección de MS17-010 en Kali Linux y ver su descripción:
kali@kali:~$ ls -lh /usr/share/nmap/scripts/smb-vuln-ms17-010.nse
kali@kali:~$ nmap --script-help smb-vuln-ms17-010
```

> 📸 **Captura 3 para el Informe:** Capturá la salida de `nmap --script-help smb-vuln-ms17-010`. Muestra claramente el identificador `CVE-2017-0144` y explica que el script consulta la tubería `IPC$` para detectar si falta el parche MS17-010.

Fase 3: Práctica con Wireshark – Captura y Filtrado de Tráfico (Clases 10 y 20)

Paso 3.1 – Capturar tráfico en vivo y aplicar filtros de análisis en Wireshark

Para complementar el punto de **Wireshark** (visto en la **Clase 10** y en el monitoreo del **Blue Team de la Clase 20**):

1. En la terminal de Kali ejecutá `sudo wireshark &` (o abrilo desde el menú de aplicaciones de Kali → *Sniffing & Spoofing* → *wireshark*).
2. En la pantalla inicial de Wireshark, hacé doble clic sobre la interfaz **`Loopback: lo`** (o `eth0`) para iniciar la captura en tiempo real.
3. Mientras Wireshark está capturando en `lo`, volvé a tu terminal y ejecutá el escaneo local del paso anterior (`sudo nmap -sV -p 80,445 127.0.0.1`) o una petición web local (`curl http://127.0.0.1`).
4. Detené la captura en Wireshark (botón del cuadrado rojo arriba a la izquierda) y en la barra de filtros (arriba) escribí: `tcp.port == 445 || tcp.port == 80` y presioná Enter.

> 📸 **Captura 4 para el Informe:** Tomá una captura de la ventana gráfica de **Wireshark** donde se vea la barra de filtro en verde (`tcp.port == 445 || tcp.port == 80`) y los paquetes TCP capturados (`[SYN]` y la respuesta `[RST, ACK]` cuando el puerto está cerrado). ¡Queda excelente como evidencia visual de la Clase 10!

Fase 4: Auditoría de Configuración en Apache y Detección con YARA / Firewall (Clases 8, 9, 12 y 20)

Paso 4.1 – Verificar la versión de Apache2 en Kali y auditar su directiva de seguridad

Kali Linux incluye **Apache2** preinstalado. Podés verificar su versión actual y comprobar en el archivo `/etc/apache2/apache2.conf` el control de seguridad que previene el **Path Traversal (`CVE-2021-41773`)**:

```
# 1. Comprobar que la versión de Apache en Kali es superior a 2.4.51 (no vulnerable a CVE-2021-41773):
kali@kali:~$ apache2 -v

# 2. Auditar la configuración de seguridad de Apache (Revisión de configuraciones - Clase 8):
kali@kali:~$ grep -A 4 "<Directory />" /etc/apache2/apache2.conf
```

Vas a ver en pantalla que aparece:

```
<Directory />
    Options FollowSymLinks
    AllowOverride None
    Require all denied
</Directory>
```

> 📸 **Captura 5 para el Informe:** Capturá esa salida de terminal. Demuestra de forma práctica cómo se realiza una **Revisión de Configuraciones (Clase 8)** y un **Hardening (Clase 20)** verificando que Apache sea versión ≥ 2.4.51 y tenga activo `Require all denied` sobre el directorio raíz `/`.

Paso 4.2 – Configurar el Firewall UFW en Kali para bloquear puertos críticos (Clases 9 y 12)

En la **Clase 9 (Firewalls)** y en la **Clase 12 (Instalación de UFW)** vimos cómo aplicar reglas de filtrado. Podés ejecutar estos comandos en tu Kali para documentar la mitigación de red contra EternalBlue:

```
# Instalar (si no está) y configurar reglas explícitas de bloqueo para SMB (139 y 445):
kali@kali:~$ sudo apt-get install -y ufw
kali@kali:~$ sudo ufw deny 445/tcp comment 'Mitigacion EternalBlue MS17-010'
kali@kali:~$ sudo ufw deny 139/tcp comment 'Bloqueo NetBIOS'
kali@kali:~$ sudo ufw enable
kali@kali:~$ sudo ufw status verbose
```

> 📸 **Captura 6 para el Informe:** Capturá la tabla que devuelve `sudo ufw status verbose` donde dice `445/tcp DENY IN Anywhere # Mitigacion EternalBlue MS17-010`. Es una evidencia real impecable para el punto de "Propuesta de solución / Mitigación".

Paso 4.3 – (Opcional) Verificar Escáneres OpenVAS / GVM o Regla YARA Defensiva (Clases 12 y 20)

Si en la **Clase 12** instalaste **OpenVAS (GVM)** o querés probar una regla defensiva de **YARA** (mencionada en la consigna del Ejercicio 2) para detectar intentos de *Log4Shell* o *Apache Path Traversal* en un archivo de log de prueba:

```
# Crear una regla defensiva YARA para detectar patrones de Path Traversal (.%2e) o
Log4Shell (${jndi:) en logs:
kali@kali:~$ cat << 'EOR' > detector_logs.yar
rule Deteccion_Intento_Apache_o_Log4Shell {
    meta:
        autor = "Equipo Blue Team - Comision 1"
        descripcion = "Detecta patrones de CVE-2021-41773 (.%2e) y CVE-2021-44228 (jndi)"
    strings:
        $apache_traversal1 = ".%2e/" nocase
        $apache_traversal2 = "%%32%65" nocase
        $log4shell_jndi    = "${jndi:" nocase
    condition:
        any of them
}
EOR

# Crear un archivo de log simulado de prueba y analizarlo con YARA:
kali@kali:~$ echo '192.168.1.50 - - "GET /cgi-bin/.%2e/.%2e/etc/passwd HTTP/1.1" 400' >
access_test.log
kali@kali:~$ yara -s detector_logs.yar access_test.log
```

> 📸 **Captura 7 para el Informe:** Capturá la salida de `yara -s detector_logs.yar access_test.log` mostrando cómo tu regla YARA detecta exactamente la cadena `.%2e/` dentro del archivo de log.

Resumen: Dónde ubicar tus capturas en el Trabajo Práctico

Captura	Comando / Herramienta en Kali	En qué parte del TP sumarla y qué etiqueta ponerle
Captura 1	`ip a` / `ifconfig`	**Ejercicio 3 (Configuración del entorno):** Etiqueta `[RESULTADO REAL]` mostrando la IP de tu máquina virtual Kali Linux.
Captura 2 y 3	`nmap -sV -p 80,139,445 127.0.0.1` y `nmap --script-help smb-vuln-ms17-010`	**Ejercicio 2 y 3 (Herramientas Nmap):** Etiqueta `[RESULTADO REAL]` evidenciando la verificación de puertos cerrados y el módulo NSE de MS17-010.
Captura 4	Interfaz gráfica de **Wireshark** filtrando `tcp.port == 445`	**Ejercicio 3 (Análisis de tráfico):** Etiqueta `[RESULTADO REAL]` mostrando la inspección de paquetes en vivo (Clase 10).
Captura 5 y 6	`apache2 -v`, `apache2.conf` y `sudo ufw status verbose`	**Ejercicio 1 y 2 (Medidas de mitigación):** Etiqueta `[RESULTADO REAL]` probando el Hardening de Apache y el bloqueo del puerto 445 en el Firewall.
Captura 7	`yara -s detector_logs.yar access_test.log`	**Ejercicio 2 y 3 (Detección Blue Team):** Etiqueta `[RESULTADO REAL]` demostrando el uso de reglas YARA sobre registros de eventos.